

VAPT Reconnaissance & Enumeration Assessment Report

Target: vulnweb.com

Prepared by: Arjun K

Course: B.Tech Computer Science

Institution: NSS College Of Engineering Palakkad

Date: July 6, 2026

Table of Contents

1. Executive Summary.....	3
2. Scope.....	4
3. Methodology.....	5
4. WHOIS Findings.....	6
5. Netcraft Findings.....	8
6.Shodan Findings.....	10
7. Subdomain Enumeration.....	14
8. Nmap Enumeration.....	17
9. Gobuster Enumeration.....	21
10. Risk Analysis.....	27
11. Recommendations.....	28
12. Conclusion.....	29

1. Executive Summary

This report presents the findings of a reconnaissance and enumeration assessment conducted against vulnweb.com, a publicly authorized test environment maintained by Acunetix for security tool practice. The assessment followed a structured five-phase methodology covering domain intelligence gathering, subdomain enumeration, service and port scanning, web directory enumeration, and internet-wide intelligence correlation via Shodan.

Six subdomains were identified, resolving to two distinct AWS infrastructure clusters running different operating systems and technology stacks: a Linux/Apache/PHP host (rest.vulnweb.com) and a Windows/IIS/ASP.NET host cluster (testaspnet.vulnweb.com, testasp.vulnweb.com). Service enumeration revealed that both hosts run significantly outdated software — Apache 2.4.25 and ASP.NET Framework 2.0.50727 on IIS 8.5 — with no TLS/HTTPS encryption in use anywhere across the environment. Web enumeration on the IIS host uncovered an active, unencrypted authentication system (login.aspx, signup.aspx) alongside legacy artifacts and a likely input-processing endpoint warranting further testing. Shodan intelligence corroborated these findings and identified 21 documented CVEs associated with the Apache instance for 2026 alone, including four rated Critical (CVSS 9.1–9.8), representing the most severe risk identified in this assessment.

Overall, the target environment's risk profile is driven primarily by unpatched legacy software and the complete absence of transport encryption, rather than any single misconfiguration. These findings and corresponding recommendations are detailed in the sections that follow.

2. Scope

This assessment was conducted against vulnweb.com and its associated subdomains, a set of intentionally exposed test applications published by Acunetix specifically for practicing security reconnaissance and enumeration techniques. As vulnweb.com is explicitly provided for this purpose — independently corroborated during the assessment via a Shodan-tagged title identifying one host as "Invicti Vulnerable REST API" — no separate written authorization was required. Testing was limited strictly to passive information gathering (WHOIS, Netcraft, Shodan) and non-destructive active enumeration (Subfinder, Nmap, Gobuster); no exploitation, data modification, or denial-of-service techniques were attempted at any point.

In-scope assets:

- vulnweb.com (root domain)
- www.vulnweb.com
- rest.vulnweb.com
- testphp.vulnweb.com
- testasp.vulnweb.com
- testaspnet.vulnweb.com

Out of scope: Exploitation of discovered vulnerabilities, denial-of-service testing, social engineering, and any third-party infrastructure not directly resolving under the vulnweb.com domain.

3. Methodology

This assessment followed a five-phase structured approach aligned with standard reconnaissance and enumeration practices used in penetration testing engagements:

1. **Target Profiling** — WHOIS and Netcraft were used to gather domain registration data, hosting information, and technology fingerprinting.
2. **Subdomain Enumeration** — Subfinder and Findomain were used to passively discover subdomains via certificate transparency logs and public data sources, followed by DNS resolution and HTTP header inspection to identify live hosts and their technology stacks.
3. **Service Enumeration** — Nmap was used to identify open ports, running services, service versions, and to run NSE vulnerability-detection scripts against discovered hosts.
4. **Web Enumeration** — Gobuster was used in a two-stage approach (directory-only, then extension-based) to discover directories, files, and application endpoints on the primary web application, with manual verification of key findings.
5. **Intelligence Gathering** — Shodan was used to independently corroborate discovered services and cross-reference them against a global vulnerability database.

All tools were run from a Kali Linux virtual machine.

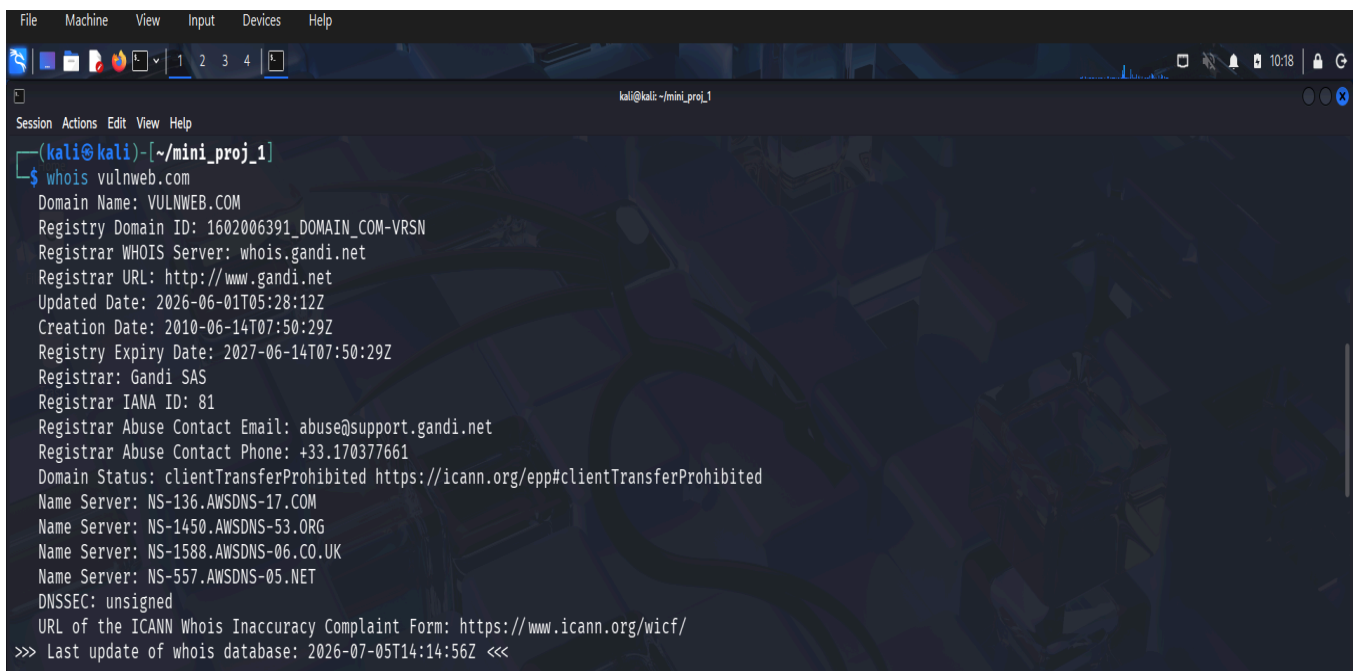
Tools used: whois, Netcraft Site Report, subfinder, findomain, dig, curl, nmap, gobuster, and Shodan.

4. WHOIS Findings

A WHOIS lookup was performed against vulnweb.com to gather domain registration details.

Field	Value
Registrar	Gandi SAS
Creation Date	14/06/2010
Expiry Date	14/06/2027
Last Updated	01/06/2026
Nameservers	NS-136.AWSDNS-17.COM NS-1450.AWSDNS-53.ORG NS-1588.AWSDNS-06.CO.UK NS-557.AWSDNS-05.NET
Domain Status	clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Registrant Info	REDACTED FOR PRIVACY Registrant Email: e7c92ba29faca2e997bfc9ce58d5c661-57148476@contact.gandi.net

Table 4.1 WHOIS Findings

A screenshot of a Kali Linux terminal window. The terminal shows the command 'whois vulnweb.com' being executed. The output displays various domain registration details for vulnweb.com, including the registrar (Gandi SAS), creation and expiry dates, nameservers, and domain status. The terminal window has a dark background with a blue and white color scheme. The command prompt is '(kali@kali) - [~/mini_proj_1]'. The output of the command is as follows:

```
(kali@kali) - [~/mini_proj_1]
$ whois vulnweb.com
Domain Name: VULNWEB.COM
Registry Domain ID: 1602006391_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.gandi.net
Registrar URL: http://www.gandi.net
Updated Date: 2026-06-01T05:28:12Z
Creation Date: 2010-06-14T07:50:29Z
Registry Expiry Date: 2027-06-14T07:50:29Z
Registrar: Gandi SAS
Registrar IANA ID: 81
Registrar Abuse Contact Email: abuse@support.gandi.net
Registrar Abuse Contact Phone: +33.170377661
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: NS-136.AWSDNS-17.COM
Name Server: NS-1450.AWSDNS-53.ORG
Name Server: NS-1588.AWSDNS-06.CO.UK
Name Server: NS-557.AWSDNS-05.NET
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-07-05T14:14:56Z <<<
```

Fig 4.1 WHOIS Finding Evidence

Observation : The domain vulnweb.com was first registered on 14/06/2010 with Gandi SAS. It is still active today with an expiry date of 14/06/2027. This means vulnweb.com has been registered for over 15 years without being abandoned. The registration record was last updated on 01/06/2026 which shows that it is regularly renewed or maintained.

The nameservers for vulnweb.com are AWSDNS-17.COM, AWSDNS-53.ORG, AWSDNS-06.CO.UK and AWSDNS-05.NET. These nameservers show that the domain name system for vulnweb.com is managed by Amazon Route 53. This makes sense because it was found that vulnweb.com is hosted on Amazon EC2. All the subdomains for vulnweb.com are linked to Amazon EC2 instances in regions.

The domain status for vulnweb.com is set to clientTransferProhibited. This is a security setting that prevents the domain from being transferred without permission. It is not a cause for concern.

The information about the person who registered vulnweb.com is not available because it is protected by WHOIS privacy. The only contact information available is a proxy email address from Gandi. This is a practice to protect the privacy of the person who registered the domain.

It is worth noting that vulnweb.com uses AWS Route 53 for its nameservers and AWS EC2 for hosting. This means that all of the infrastructure for vulnweb.com, including the domain name system, computing and hosting is managed by a cloud provider, which is Amazon Web Services. This is a setup, for many websites and testing platforms, including vulnweb.com.

5. Netcraft Findings

Netcraft's Site Report tool was used to gather hosting, infrastructure, and technology-fingerprinting details for vulnweb.com

Field	Value
Hosting Provider	ec2-44-228-249-3.us-west-2.compute.amazonaws.comr
IP Address	44.228.249.3
Netblock Owner / ASN	AS16509 Amazon.com, Inc.
Server Technology	Amazon Route 53
First Seen / Hosting History	August 2023

Table 5.1 Netcraft findings

https://sitereport.netcraft.com/?url=http://vulnweb.com

</

Fig 5.1 Netcraft sitereport

```
(kali@kali)-[~/mini_proj_1]
$ curl -s "https://ipinfo.io/44.228.249.3/json"
{
  "ip": "44.228.249.3",
  "hostname": "ec2-44-228-249-3.us-west-2.compute.amazonaws.com",
  "city": "Boardman",
  "region": "Oregon",
  "country": "US",
  "loc": "45.8399,-119.7006",
  "org": "AS16509 Amazon.com, Inc.",
  "postal": "97818",
  "timezone": "America/Los_Angeles",
  "readme": "https://ipinfo.io/missingauth"
}
```

Fig 5.2 ASN Detail

Observation : The domain is hosted on AWS EC2 infrastructure

6.Shodan Findings

Shodan was used to independently corroborate service and vulnerability data for the two primary infrastructure clusters identified during earlier phases: rest.vulnweb.com (18.215.71.186) and testaspnet.vulnweb.com/testasp.vulnweb.com (44.238.29.244).

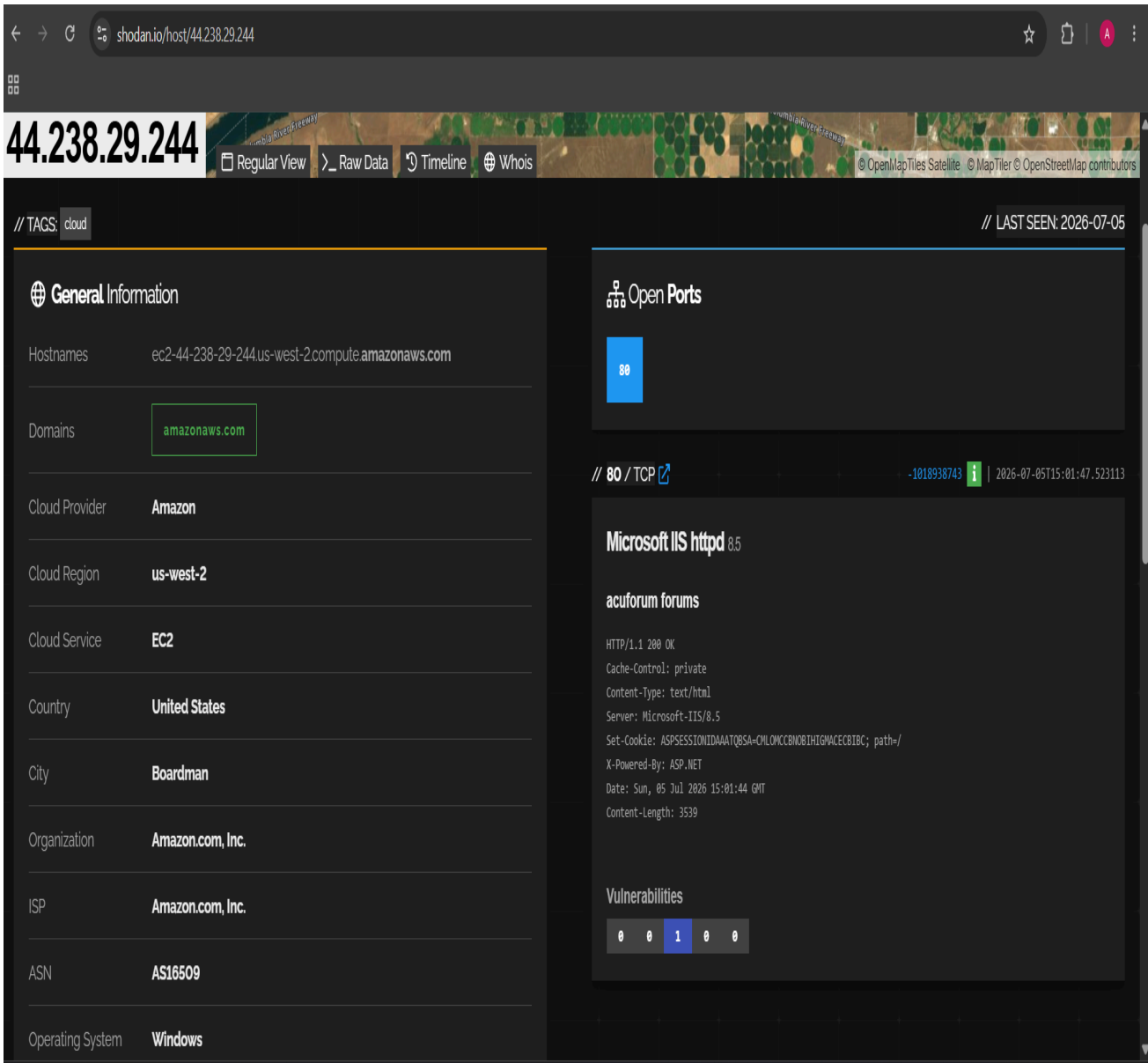


Fig 6.1 : 44.238.29.244 Shodan general info & Open port panel

The screenshot shows the Shodan host page for IP 18.215.71.186. The page is divided into two main sections: General Information and Open Ports.

General Information:

- Hostnames: ec2-18-215-71-186.compute-1.amazonaws.com
- Domains: amazonaws.com
- Cloud Provider: Amazon
- Cloud Region: us-east-1
- Cloud Service: EC2
- Country: United States
- City: Ashburn
- Organization: Amazon Technologies Inc.
- ISP: Amazon.com, Inc.
- ASN: AS14618

Open Ports:

- 80 (TCP)

Apache httpd 2.4.25:

Invicti Vulnerable REST API

HTTP/1.1 200 OK
 Date: Tue, 30 Jun 2026 06:11:09 GMT
 Server: Apache/2.4.25 (Debian)
 X-Powered-By: PHP/7.1.26
 Vary: Accept-Encoding
 Content-Length: 3556
 Content-Type: text/html; charset=UTF-8

Vulnerabilities:

CVE	Score	Count
CVE-2026-49975	7.5	28
CVE-2026-44631	9.8	68
CVE-2026-44186	7.3	49
CVE-2026-44185	7.3	5
		0

Fig 6.2 : 18.215.71.186 Shodan general info & Open port panel

The screenshot shows the Shodan host page for IP 18.215.71.186, specifically the Vulnerabilities section. The page displays a list of vulnerabilities with their CVE IDs, scores, and descriptions.

Vulnerabilities:

- CVE-2026-49975** (Score: 7.5): Memory Allocation with Excessive Size Value vulnerability in Apache HTTP Server's mod_http leads to denial of service via malicious HTTP requests. This issue affects Apache HTTP Server: from 2.4.17 through 2.4.67.
- CVE-2026-44631** (Score: 9.8): Buffer Underwrite vulnerability in Apache HTTP Server on crafted regular expressions in the configuration. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.
- CVE-2026-44186** (Score: 7.3): Loop with Unreachable Exit Condition ('Infinite Loop') vulnerability in the mod_proxy_ftp module in Apache HTTP Server with an attacker controlled backend FTP server. This issue affects undefined: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.
- CVE-2026-44185** (Score: 7.3): Buffer Over-read vulnerability in Apache HTTP Server via outbound OCSP requests to an attacker controlled OCSP server. This issue affects Apache HTTP Server: from 2.4.0 through 2.4.67. Users are recommended to upgrade to version 2.4.68, which fixes the issue.

Fig 6.3 : 18.215.71.186 Shodan Vulnerability report

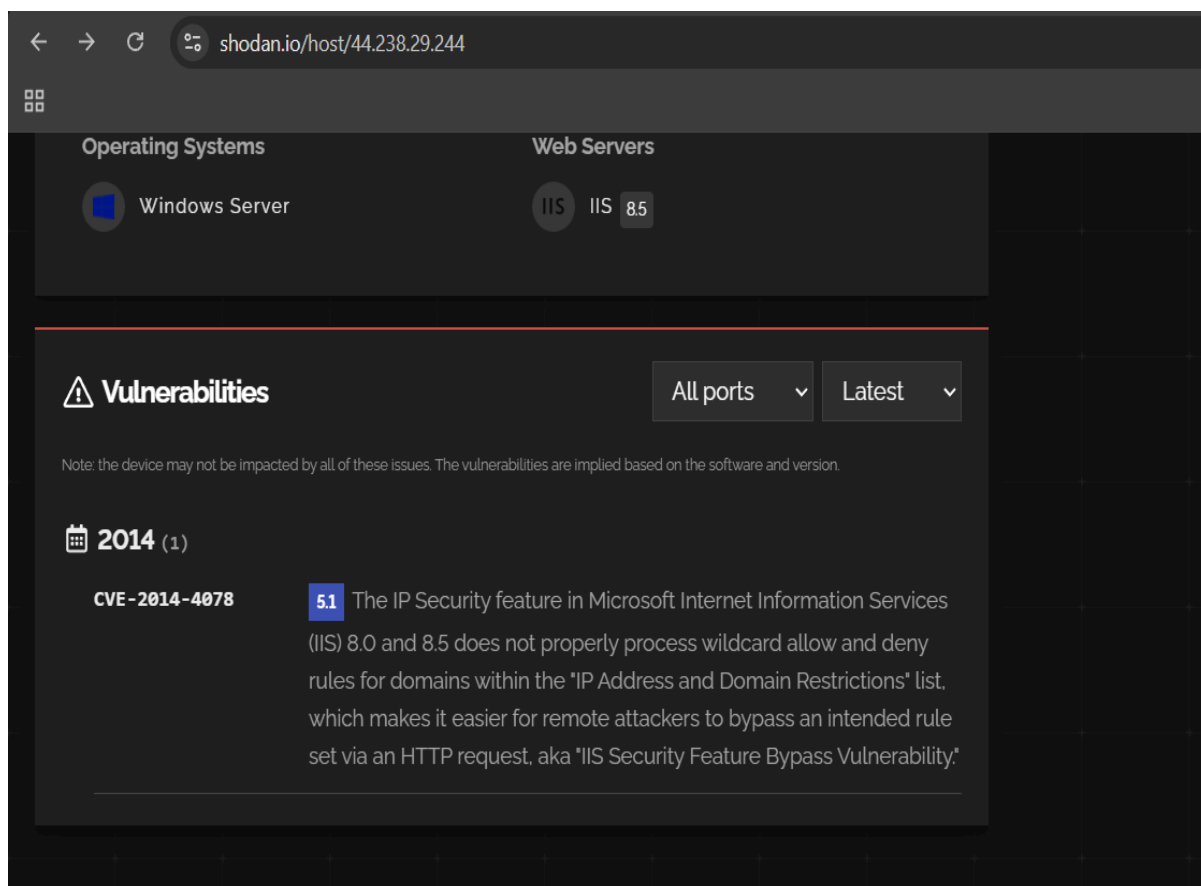


Fig 6.4 : 44.238.29.244 Shodan Vulnerability report

CVE	CVSS	Summary
CVE-2026-44631	9.8 Critical	Buffer underwrite via crafted regex in configuration
CVE-2026-29167	9.8 Critical	Use-after-free in mod_lldap
CVE-2026-28780	9.8 Critical	Heap-based buffer overflow in mod_proxy_ajp
CVE-2026-42535	9.1 Critical	Path handling issue in mod_dav_fs
CVE-2026-49975	7.5 High	DoS via mod_http excessive memory allocation
CVE-2026-44186	7.3 High	Infinite loop in mod_proxy_ftp
CVE-2026-44185	7.3 High	Buffer over-read via outbound OCSP requests
CVE-2026-44119	5.5 Medium	Privilege management bypass via .htaccess

Table 6.1 Vulnerability findings — rest.vulnweb.com

Observation: Shodan's vulnerability data independently corroborates and substantially expands on findings from the Nmap Enumeration phase. The Apache 2.4.25 instance on rest.vulnweb.com is associated with 21 documented CVEs for 2026, including four rated Critical (CVSS 9.1–9.8) covering buffer overflow, use-after-free, and path manipulation vulnerabilities — representing the single highest-severity risk identified across this entire assessment. By comparison, the IIS 8.5 instance carries only one associated CVE of moderate severity, though the ASP.NET Framework 2.0.50727 running on top of it is separately outdated and not reflected in IIS-specific CVE data.

7. Subdomain Enumeration

- Performed using both Subfinder and Findomain

```
(kali@kali) [~/mini_proj_1]
$ subfinder -d vulnweb.com -o subfinder_output.txt

projectdiscovery.io

[INF] Current subfinder version v2.12.0 (outdated)
[INF] Loading provider config from /home/kali/.config/subfinder/provider-config.yaml
[INF] Enumerating subdomains for vulnweb.com
```

Fig 7.1 Subfinder initial execution

```
(kali@kali) [~/mini_proj_1]
$ cat subfinder_output.txt
testphp.vulnweb.com
testsp.vulnweb.com
phpptest.vulnweb.com
rest.vulnweb.com
testasp.vulnweb.com
testaspnet.vulnweb.com
testhtml5.vulnweb.com
testpphp.vulnweb.com
u003etestasp.vulnweb.com
www.vulnweb.com
antivirus1.vulnweb.com
testhtml5.vulnweb.com
www.vulnweb.com
antivirus1.vulnweb.com
rest.vulnweb.com
testaspnet.vulnweb.com
testhtml5.vulnweb.com
testphp.vulnweb.com
testsp.vulnweb.com
u003etestasp.vulnweb.com
phpptest.vulnweb.com
testasp.vulnweb.com
testhtml5.vulnweb.com
testpphp.vulnweb.com
```

Fig 7.2 Subfinder result

```
(kali@kali)-[~/mini_proj_1]
$ findomain -t vulnweb.com --ip

Target => vulnweb.com

Searching in the Urlscan.io API...
Searching in the Threatcrowd API...
Searching in the AnubisDB API...
Searching in the Sublist3r API...
Searching in the Crtsh database API...
Searching in the CertSpotter API...
Searching in the Threatminer API...

Running wildcards detection for vulnweb.com...
No wilcards detected for vulnweb.com, nice!

Performing asynchronous resolution for 6 subdomains for the target vulnweb.com, it will take a while...

rest.vulnweb.com,18.215.71.186
vulnweb.com,44.228.249.3
www.vulnweb.com,44.228.249.3
testaspnet.vulnweb.com,44.238.29.244
testasp.vulnweb.com,44.238.29.244
testphp.vulnweb.com,44.228.249.3

Job finished in 5 seconds.

Good luck Hax0r 🐼!
```

Fig 7.3 Resolved Subdomains IP

- Total subdomains discovered: 36

Subdomain	IP Address	Hosting Region
rest.vulnweb.com	18.215.71.186	AWS us-east-1
vulnweb.com	44.228.249.3	AWS
www.vulnweb.com	44.228.249.3	AWS
testaspnet.vulnweb.com	44.238.29.244	AWS us-west-2
testasp.vulnweb.com	44.238.29.244	AWS us-west-2
testphp.vulnweb.com	44.228.249.3	AWS

Table 7.1 Resolved subdomains

Subdomain	Server	Framework	Notes
rest.vulnweb.com	Apache 2.4.25 (Debian)	PHP 7.1.26	Responsive
testaspnet.vulnweb.com	Microsoft IIS 8.5	ASP.NET (Framework 2.0.50727)	Responsive, outdated framework
testasp.vulnweb.com	Microsoft IIS 8.5	ASP.NET	Responsive
testphp.vulnweb.com	—	—	Connection timeout — did not respond

Table 7.2 Technologies used on subdomains

```

kali@kali: ~/mini_proj_1
curl: (7) Failed to connect to testphp.vulnweb.com port 80 after 21105 ms: Could not connect to server

(kali@kali)-[~/mini_proj_1]
└─$ curl -I http://rest.vulnweb.com
HTTP/1.1 200 OK
Date: Sun, 05 Jul 2026 16:18:47 GMT
Server: Apache/2.4.25 (Debian)
X-Powered-By: PHP/7.1.26
Content-Type: text/html; charset=UTF-8

(kali@kali)-[~/mini_proj_1]
└─$ curl -I http://testaspnet.vulnweb.com
HTTP/1.1 200 OK
Cache-Control: private
Content-Length: 13984
Content-Type: text/html; charset=utf-8
Server: Microsoft-IIS/8.5
X-AspNet-Version: 2.0.50727
Set-Cookie: ASP.NET_SessionId=yra3ms55p3kto1z2mebip1vp; path=/; HttpOnly
X-Powered-By: ASP.NET
Date: Sun, 05 Jul 2026 16:19:17 GMT

(kali@kali)-[~/mini_proj_1]
└─$ curl -I http://testasp.vulnweb.com
HTTP/1.1 200 OK
Cache-Control: private
Content-Length: 3537
Content-Type: text/html
Server: Microsoft-IIS/8.5
Set-Cookie: ASPSESSIONIDAAATQBSA=IGIJBDCBJJEGNGBBELMIAKKJ; path=/
X-Powered-By: ASP.NET
Date: Sun, 05 Jul 2026 16:20:13 GMT

```

Fig 7.4 Technology difference of Subdomains

rest.vulnweb.com was identified as the most interesting subdomain, as it resolves to a distinct IP address (18.215.71.186) on entirely separate AWS infrastructure (us-east-1) compared to the other subdomains (us-west-2), and runs a completely different technology stack — Apache/PHP on Linux, versus IIS/ASP.NET on Windows for the remaining hosts.

8. Nmap Enumeration

Nmap was used to perform host discovery, full port scanning, Version detection against subdomains.

```
(kali@kali)-[~/mini_proj_1]
$ nmap -sn rest.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-06 06:19 EDT
Nmap scan report for rest.vulnweb.com (18.215.71.186)
Host is up (0.00069s latency).
rDNS record for 18.215.71.186: ec2-18-215-71-186.compute-1.amazonaws.com
Nmap done: 1 IP address (1 host up) scanned in 5.80 seconds
```

Fig 8.1 Nmap host discovery of Subdomain

```
(kali@kali)-[~/mini_proj_1]
$ nmap -p- -T4 --min-rate=1000 -oN nmap_allports.txt rest.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-06 06:24 EDT
Nmap scan report for rest.vulnweb.com (18.215.71.186)
Host is up (0.23s latency).
rDNS record for 18.215.71.186: ec2-18-215-71-186.compute-1.amazonaws.com
Not shown: 65534 filtered tcp ports (no-response)
PORT      STATE SERVICE
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 203.35 seconds
```

Fig 8.2 Open ports discovery of Subdomain

```
(kali@kali)-[~/mini_proj_1]
$ nmap -sV -sC -p 80 -oN nmap_detailed.txt rest.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-06 06:31 EDT
Nmap scan report for rest.vulnweb.com (18.215.71.186)
Host is up (0.00077s latency).
rDNS record for 18.215.71.186: ec2-18-215-71-186.compute-1.amazonaws.com

PORT      STATE  SERVICE VERSION
80/tcp    filtered http

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.10 seconds
```

Fig 8.3 Deep scan on the open port

```

(kali㉿kali)-[~/mini_proj_1]
└─$ nmap -sV -p 80,443 testaspnet.vulnweb.com -oN nmap_testaspnet.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-06 06:49 EDT
Nmap scan report for testaspnet.vulnweb.com (44.238.29.244)
Host is up (0.032s latency).
rDNS record for 44.238.29.244: ec2-44-238-29-244.us-west-2.compute.amazonaws.com

PORT      STATE      SERVICE VERSION
80/tcp    open      http      Microsoft IIS httpd 8.5
443/tcp   filtered  https
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.47 seconds

(kali㉿kali)-[~/mini_proj_1]
└─$ nmap -sV -p 80,443 testasp.vulnweb.com -oN nmap_testasp.txt
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-06 06:51 EDT
Nmap scan report for testasp.vulnweb.com (44.238.29.244)
Host is up (0.033s latency).
rDNS record for 44.238.29.244: ec2-44-238-29-244.us-west-2.compute.amazonaws.com

PORT      STATE      SERVICE VERSION
80/tcp    open      http      Microsoft IIS httpd 8.5
443/tcp   filtered  https
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 16.49 seconds

```

Fig 8.4 Service version scan of other subdomains

Subdomain	IP	Port 80	Port 443	Server	OS
rest.vulnweb.com	18.215.71.186	open — Apache 2.4.25 (Debian)	filtered	Apache	Linux
testaspnet.vulnweb.com	44.238.29.244	open — IIS 8.5	filtered	IIS	Windows
testasp.vulnweb.com	44.238.29.244	open — IIS 8.5	filtered	IIS	Windows

Table 8.1 Nmap Findings

```
(kali㉿kali)-[~/mini_proj_1]
└─$ nmap -p 80 --script vuln -T2 -Pn -oN nmap_vuln_retry.txt rest.vulnweb.com
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-06 06:41 EDT
Nmap scan report for rest.vulnweb.com (18.215.71.186)
Host is up (0.26s latency).
rDNS record for 18.215.71.186: ec2-18-215-71-186.compute-1.amazonaws.com

PORT      STATE SERVICE
80/tcp    open  http
|_http-aspnet-debug: ERROR: Script execution failed (use -d to debug)
|_http-fileupload-exploiter:
|_
|_      Couldn't find a file-type field.
|_http-dombased-xss: Couldn't find any DOM based XSS.
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
|_http-csrf: Couldn't find any CSRF vulnerabilities.

Nmap done: 1 IP address (1 host up) scanned in 140.83 seconds
```

Fig 8.6 rest.vulnweb.com vulnerability scan

Observations:

1. No TLS/HTTPS anywhere. Port 443 was reported as filtered on all three scanned subdomains, and no HTTP-to-HTTPS redirect was observed. All traffic — including any credentials or session data — is transmitted in plaintext.
2. Mixed infrastructure increases attack surface. The environment spans two AWS regions and two operating system families (Linux/Apache and Windows/IIS), meaning two entirely separate patching and hardening processes would be needed to secure it.
3. Outdated software at two layers. testaspnet.vulnweb.com reveals ASP.NET Framework 2.0.50727 (released 2005, unsupported), running on IIS 8.5 (shipped with Windows Server 2012 R2, also legacy) — both the application framework and web server are outdated.
4. Automated vulnerability scripts returned clean results for XSS/CSRF on rest.vulnweb.com, but this should not be read as confirmation of security — NSE scripts have limited crawl depth and only test specific known patterns; manual testing would be needed for full coverage.
5. Rate-limiting/filtering behavior observed. The first vulnerability scan attempt showed port 80 as "filtered," while a slower retry (-T2 -Pn) succeeded — indicating the presence of basic automated-traffic detection, likely an AWS security group or WAF rule.

Script	Result
http-aspnet-debug	Script execution failed (likely non-applicable — target is not ASP.NET)
http-fileupload-exploiter	No file upload field found on tested page
http-dombased-xss	No DOM-based XSS found
http-stored-xss	No stored XSS found
http-csrf	No CSRF vulnerabilities found

Table 8.2 Vulnerability scan findings

9. Gobuster Enumeration

Gobuster was used to perform directory and file enumeration against testaspnet.vulnweb.com, the web service identified as highest priority in the Nmap Enumeration phase due to its outdated ASP.NET framework and lack of TLS encryption.

```
(kali@kali)-[~/mini_proj_1]
$ gobuster dir -u http://testaspnet.vulnweb.com -w /usr/share/wordlists/dirb/common.txt -o gobuster_testaspnet.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:                http://testaspnet.vulnweb.com
[+] Method:             GET
[+] Threads:            10
[+] Wordlist:            /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.8
[+] Timeout:            10s

Starting gobuster in directory enumeration mode

Progress: 70 / 4613 (1.52%)
```

Fig 9.1 Gobuster scan running

```
(kali@kali)-[~/mini_proj_1]
$ gobuster dir -u http://testaspnet.vulnweb.com -w /usr/share/wordlists/dirb/common.txt -o gobuster_testaspnet.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:                http://testaspnet.vulnweb.com
[+] Method:             GET
[+] Threads:            10
[+] Wordlist:            /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:         gobuster/3.8
[+] Timeout:            10s

Starting gobuster in directory enumeration mode

/_vti_cnf               (Status: 301) [Size: 162] [→ http://testaspnet.vulnweb.com/_vti_cnf/]
/ads                    (Status: 301) [Size: 157] [→ http://testaspnet.vulnweb.com/ads/]
/aspnet_client          (Status: 301) [Size: 167] [→ http://testaspnet.vulnweb.com/aspnet_client/]
/cgi-bin                (Status: 301) [Size: 161] [→ http://testaspnet.vulnweb.com/cgi-bin/]
/cgi-bin/               (Status: 403) [Size: 1233]
/favicon.ico            (Status: 200) [Size: 894]
/Images                 (Status: 301) [Size: 160] [→ http://testaspnet.vulnweb.com/Images/]
/images                 (Status: 301) [Size: 160] [→ http://testaspnet.vulnweb.com/images/]
/jscripts               (Status: 301) [Size: 162] [→ http://testaspnet.vulnweb.com/jscripts/]
/robots.txt             (Status: 200) [Size: 13]
/temp                   (Status: 301) [Size: 158] [→ http://testaspnet.vulnweb.com/temp/]
/TEMP                   (Status: 301) [Size: 158] [→ http://testaspnet.vulnweb.com/TEMP/]
/utils                  (Status: 301) [Size: 159] [→ http://testaspnet.vulnweb.com/utils/]
Progress: 4613 / 4613 (100.00%)

Finished
```

Fig 9.2 Gobuster scan Output

Path	Status	Notes
/_vti_cnf	301	Legacy FrontPage Server Extensions artifact
/ads	301	Directory exists
/aspnet_client	301	Standard ASP.NET client script folder
/cgi-bin	301 → 403	CGI execution directory; access restricted
/favicon.ico	200	Standard icon, no risk
/Images, /images	301	Confirms Windows case-insensitive filesystem
/jscripts	301	JavaScript directory
/robots.txt	200	Small file (13 bytes); reviewed in Stage 3
/TEMP, /temp	301 → 403	Temp directory; access restricted on manual check
/utils	301 → 403	Utility directory; access restricted on manual check

Table 9.1 Directory Enumeration findings

Based on the confirmed ASP.NET/IIS technology stack, a follow-up scan was conducted using file extensions relevant to the platform, to probe for application pages and configuration artifacts not visible in a directory-only scan.

```
(kali@kali)-[~/mini_proj_1]
$ gobuster dir -u http://testaspnet.vulnweb.com -w /usr/share/wordlists/dirb/common.txt -x asp,aspx,txt,bak,config -o gobuster_testaspnet_ext.txt

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://testaspnet.vulnweb.com
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: asp,aspx,txt,bak,config
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

Progress: 271 / 27678 (0.98%)
```

Fig 9.3 Gobuster extension scan running

```

(kali@kali)-[~/mini_proj_1]
$ gobuster dir -u http://testaspnet.vulnweb.com -w /usr/share/wordlists/dirb/common.txt -x asp,aspx,txt,bak,config -o gobuster_testaspnet_ext.txt

```

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```

[+] Url:           http://testaspnet.vulnweb.com
[+] Method:        GET
[+] Threads:       10
[+] Wordlist:       /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent:     gobuster/3.8
[+] Extensions:    asp,aspx,txt,bak,config
[+] Timeout:       10s

```

Starting gobuster in directory enumeration mode

```

/_vti_cnf          (Status: 301) [Size: 162] [→ http://testaspnet.vulnweb.com/_vti_cnf/]
/about.aspx        (Status: 200) [Size: 14536]
/About.aspx        (Status: 200) [Size: 14536]
/ads               (Status: 301) [Size: 157] [→ http://testaspnet.vulnweb.com/ads/]
/aspnet_client     (Status: 301) [Size: 167] [→ http://testaspnet.vulnweb.com/aspnet_client/]
/cgi-bin           (Status: 301) [Size: 161] [→ http://testaspnet.vulnweb.com/cgi-bin/]
/cgi-bin/          (Status: 403) [Size: 1233]
/comments.aspx     (Status: 200) [Size: 0]
/default.aspx      (Status: 200) [Size: 13981]
/Default.aspx      (Status: 200) [Size: 13981]
/favicon.ico       (Status: 200) [Size: 894]

```

Fig 9.4 Gobuster extension scan output 1

Starting gobuster in directory enumeration mode

```

/_vti_cnf          (Status: 301) [Size: 162] [→ http://testaspnet.vulnweb.com/_vti_cnf/]
/about.aspx        (Status: 200) [Size: 14536]
/About.aspx        (Status: 200) [Size: 14536]
/ads               (Status: 301) [Size: 157] [→ http://testaspnet.vulnweb.com/ads/]
/aspnet_client     (Status: 301) [Size: 167] [→ http://testaspnet.vulnweb.com/aspnet_client/]
/cgi-bin           (Status: 301) [Size: 161] [→ http://testaspnet.vulnweb.com/cgi-bin/]
/cgi-bin/          (Status: 403) [Size: 1233]
/comments.aspx     (Status: 200) [Size: 0]
/default.aspx      (Status: 200) [Size: 13981]
/Default.aspx      (Status: 200) [Size: 13981]
/favicon.ico       (Status: 200) [Size: 894]
/images            (Status: 301) [Size: 160] [→ http://testaspnet.vulnweb.com/images/]
/Images            (Status: 301) [Size: 160] [→ http://testaspnet.vulnweb.com/Images/]
/jscripts          (Status: 301) [Size: 162] [→ http://testaspnet.vulnweb.com/jscripts/]
/login.aspx        (Status: 200) [Size: 13332]
/Login.aspx        (Status: 200) [Size: 13332]
/logout.aspx       (Status: 302) [Size: 161] [→ /login.aspx?ReturnUrl=%2flogout.aspx]
/robots.txt        (Status: 200) [Size: 13]
/robots.txt        (Status: 200) [Size: 13]
/rssfeed.aspx      (Status: 200) [Size: 2118]
/signup.aspx       (Status: 200) [Size: 13023]
/temp              (Status: 301) [Size: 158] [→ http://testaspnet.vulnweb.com/temp/]
/TEMP              (Status: 301) [Size: 158] [→ http://testaspnet.vulnweb.com/TEMP/]
/test.txt          (Status: 200) [Size: 3]
/utils             (Status: 301) [Size: 159] [→ http://testaspnet.vulnweb.com/utils/]
Progress: 27678 / 27678 (100.00%)

```

Finished

Fig 9.5 Gobuster extension scan output 2

Path	Status	Category	Risk Notes
/login.aspx, /Login.aspx	200	Authentication	Login form exposed over unencrypted HTTP
/signup.aspx	200	Authentication	User registration exposed
/logout.aspx	302 → /login.aspx?ReturnUrl=...	Session handling	ReturnUrl parameter present — potential open redirect if unvalidated
/comments.aspx	200 (0 bytes)	Application logic	Likely POST-handling endpoint (see 8.3)
/test.txt	200	Leftover file	Developer test artifact (see 8.3)
/default.aspx, /Default.aspx	200	Main page	Expected/standard
/about.aspx	200	Content page	Standard
/rssfeed.aspx	200	Data feed	Possible internal content exposure

Table 9.2 Directory extension based Enumeration findings

```

(kali㉿kali)-[~/mini_proj_1]
$ curl -I http://testaspnet.vulnweb.com/cgi-bin/
HTTP/1.1 403 Forbidden
Content-Length: 1233
Content-Type: text/html
Server: Microsoft-IIS/8.5
X-Powered-By: ASP.NET
Date: Tue, 07 Jul 2026 14:47:36 GMT

(kali㉿kali)-[~/mini_proj_1]
$ curl -I http://testaspnet.vulnweb.com/TEMP/
HTTP/1.1 403 Forbidden
Content-Length: 1233
Content-Type: text/html
Server: Microsoft-IIS/8.5
X-Powered-By: ASP.NET
Date: Tue, 07 Jul 2026 14:48:06 GMT

(kali㉿kali)-[~/mini_proj_1]
$ curl -I http://testaspnet.vulnweb.com/utils/
HTTP/1.1 403 Forbidden
Content-Length: 1233
Content-Type: text/html
Server: Microsoft-IIS/8.5
X-Powered-By: ASP.NET
Date: Tue, 07 Jul 2026 14:48:28 GMT

```

Fig 9.6 Restricted directories

```
(kali㉿kali)-[~/mini_proj_1]
$ curl http://testaspnet.vulnweb.com/test.txt
aaa

(kali㉿kali)-[~/mini_proj_1]
$ curl http://testaspnet.vulnweb.com/robots.txt
User-agent: *

(kali㉿kali)-[~/mini_proj_1]
$ curl -I http://testaspnet.vulnweb.com/comments.aspx
HTTP/1.1 200 OK
Cache-Control: private
Content-Length: 0
Server: Microsoft-IIS/8.5
X-AspNet-Version: 2.0.50727
Set-Cookie: ASP.NET_SessionId=kc5erljwhf4ei245orwzsgh; path=/; HttpOnly
X-Powered-By: ASP.NET
Date: Tue, 07 Jul 2026 14:43:35 GMT
```

Fig 9.7 Leftover file content

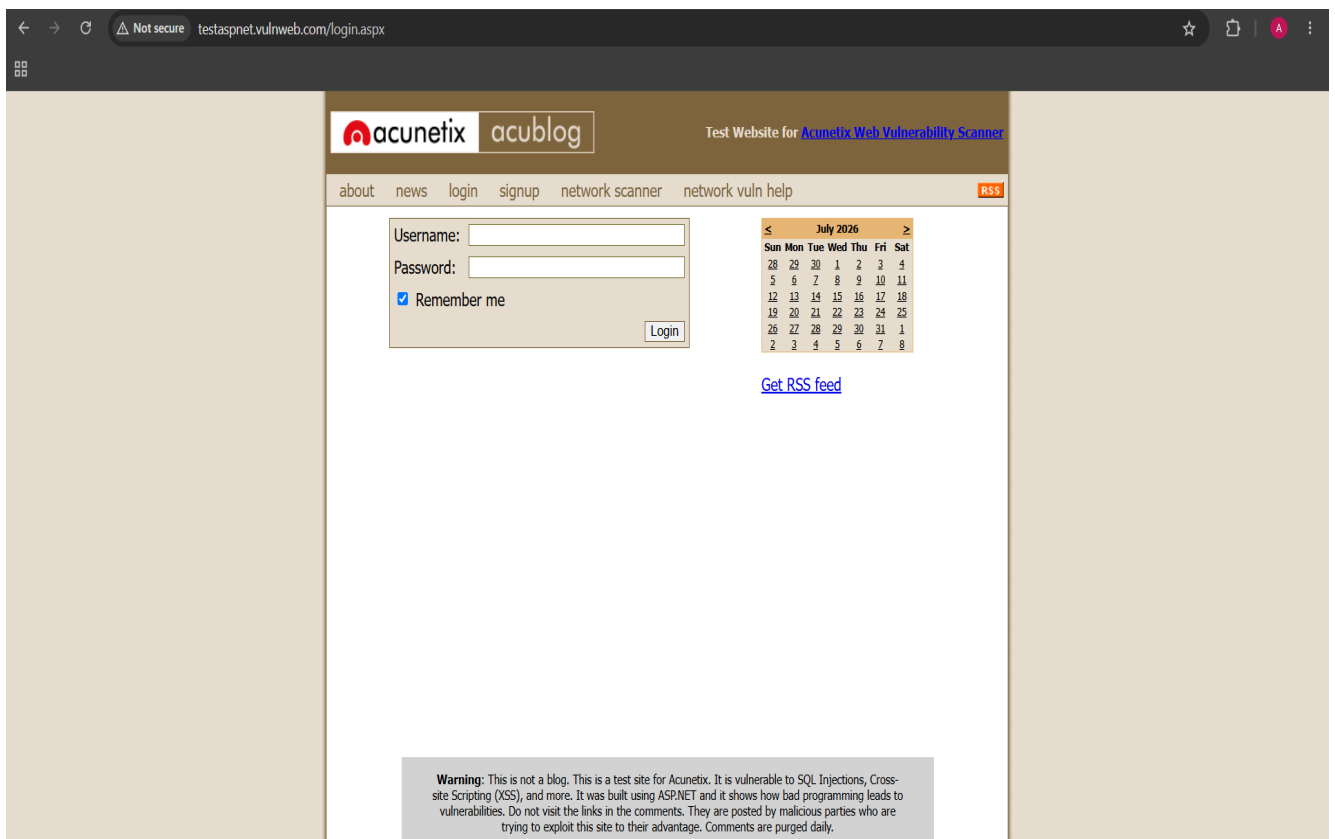


Fig 9.8 Login page(login.aspx)

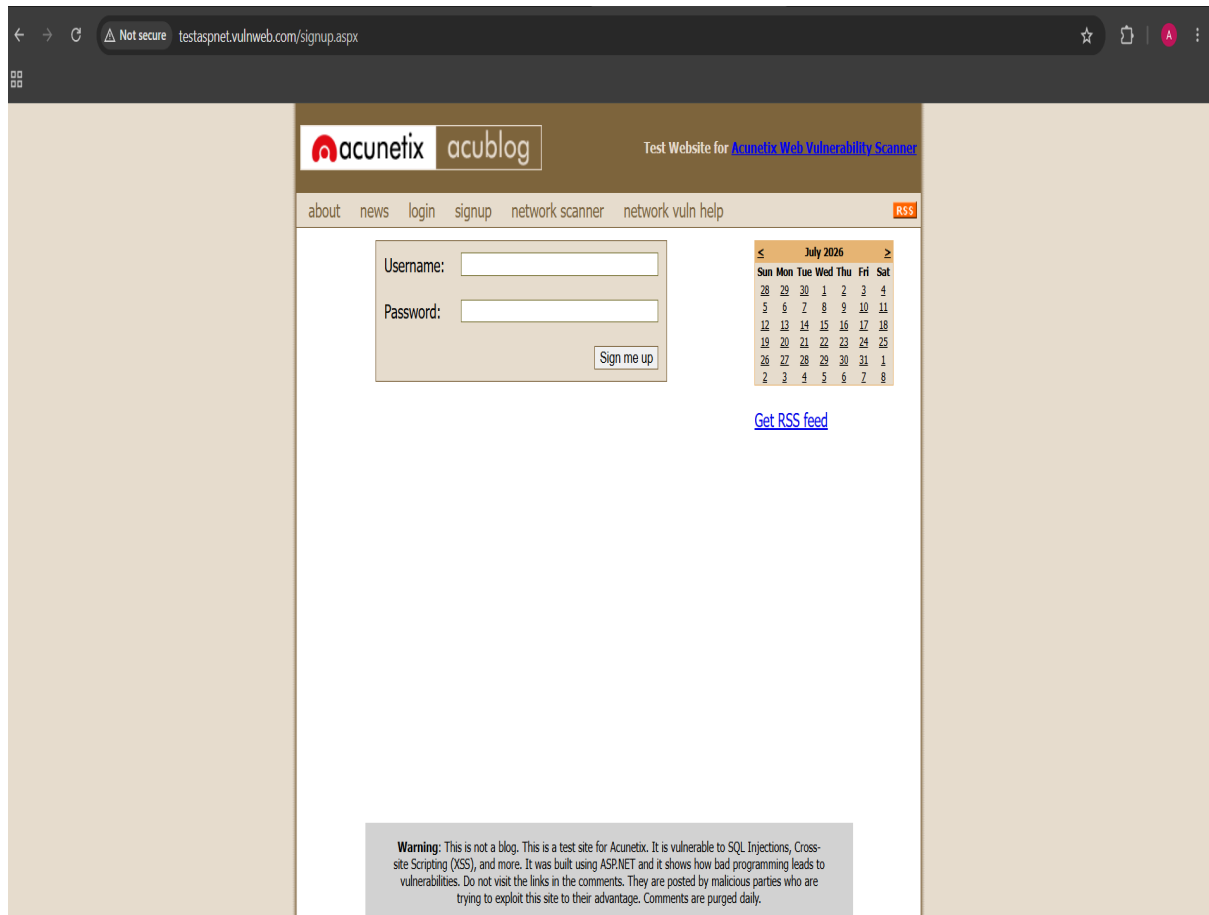


Fig 9.9 Signup page(signup.aspx)

Observations:

The Gobuster enumeration phase surfaced a coherent and significant risk narrative when combined with earlier findings. The discovery of /login.aspx and /signup.aspx confirms an active authentication mechanism on a host already identified as running an outdated ASP.NET Framework (2.0.50727) over unencrypted HTTP — meaning credentials submitted through this login form are transmitted in plaintext and vulnerable to interception. The /comments.aspx endpoint's behavior suggests it processes user-submitted input, making it a candidate for injection-based testing (e.g., stored XSS) in a full penetration test. While legacy artifacts (/cgi-bin, /_vti_cnf, /TEMP) were discovered, manual verification confirmed these are properly access-restricted at the server level, indicating at least partial security hardening is in place despite the outdated software stack.

10. Risk Analysis

The following risks were identified across the assessed environment, ranked by severity based on combined evidence from all assessment phases.

1. Critical — Outdated Apache HTTP Server (rest.vulnweb.com)

Apache 2.4.25 is associated with 21 documented CVEs for 2026, including four Critical-severity vulnerabilities (CVSS 9.1–9.8) enabling buffer overflow, use-after-free, and path manipulation attacks. This represents the most severe risk in the environment. **Recommended fix:** upgrade to Apache 2.4.68 or later.

2. High — Outdated ASP.NET Framework and unencrypted authentication (testaspnet.vulnweb.com)

The host runs ASP.NET Framework 2.0.50727 (released 2005, unsupported) on IIS 8.5 (also legacy), and exposes a live login/signup system (login.aspx, signup.aspx) over plain HTTP with no TLS. Credentials submitted through this form are transmitted in plaintext, vulnerable to interception. **Recommended fix:** upgrade the ASP.NET Framework, enforce HTTPS with a valid TLS certificate.

3. Medium — Absence of TLS/HTTPS across the entire environment

Port 443 was found filtered/unavailable on all scanned subdomains with no HTTP-to-HTTPS redirection in place. All application traffic, including any future authentication or form submissions, travels unencrypted. **Recommended fix:** implement TLS across all subdomains.

4. Medium — Fragmented infrastructure across regions and platforms

The environment spans two AWS regions (us-east-1, us-west-2) under two different ASNs, running two different operating systems (Linux and Windows). This fragmentation increases the likelihood of inconsistent patching and monitoring practices. **Recommended fix:** consolidate infrastructure management or apply unified patch-management policy across both clusters.

5. Low — Legacy artifacts and developer hygiene issues

Discovery of /_vti_cnf (FrontPage remnant), /cgi-bin, and a leftover test.txt file indicate incomplete cleanup of legacy or development artifacts, though manual testing confirmed these are not directly exploitable (directories return 403, file contains placeholder text). **Recommended fix:** routine cleanup of unused legacy directories and test files from production web roots.

6. Low — Unresponsive service (testphp.vulnweb.com)

This subdomain resolved via DNS but failed to respond to HTTP requests during testing, indicating a possible availability or configuration issue. **Recommended fix:** investigate service status; confirm intended availability.

11. Recommendations

1. Upgrade Apache HTTP Server on rest.vulnweb.com from 2.4.25 to 2.4.68 or later to remediate all 21 identified CVEs, prioritizing the four Critical-severity issues.
2. Upgrade the ASP.NET Framework on testaspnet.vulnweb.com/testasp.vulnweb.com from version 2.0.50727 to a currently supported .NET version, and update IIS beyond 8.5.
3. Implement TLS/HTTPS across all subdomains, with enforced HTTP-to-HTTPS redirection, particularly to protect the discovered login.aspx authentication endpoint.
4. Review and harden comments.aspx and similar input-processing endpoints for injection vulnerabilities (e.g., stored XSS), given their likely role in handling user-submitted content.
5. Remove or restrict legacy artifacts such as /_vti_cnf, /cgi-bin, and leftover test files from the production web root.
6. Investigate the availability of testphp.vulnweb.com to determine whether its non-responsiveness is intentional or a misconfiguration.
7. Standardize infrastructure management across the two AWS regions/ASNs to ensure consistent patch cadence and monitoring coverage.

12. Conclusion

This assessment successfully identified a broad attack surface across vulnweb.com and its subdomains using a structured, tool-driven reconnaissance and enumeration methodology. The environment's primary risk drivers were found to be outdated, unpatched software — most critically an Apache HTTP Server instance associated with multiple Critical-severity CVEs — compounded by a complete absence of transport-layer encryption across all discovered services. While some access controls were confirmed to be functioning correctly (restricted legacy directories), the presence of a live, unencrypted authentication system on outdated software represents a realistic and significant risk. The findings and recommendations in this report provide a clear remediation roadmap prioritized by severity, and demonstrate the value of combining passive intelligence sources (WHOIS, Netcraft, Shodan) with active enumeration tools (Subfinder, Nmap, Gobuster) to build a complete picture of an organization's external attack surface.

Final Questions

1. How many subdomains were discovered?

36

2. Which subdomain was most interesting and why?

rest.vulnweb.com was the most interesting subdomain. It resolves to a distinct IP address (18.215.71.186) on separate AWS infrastructure (different region and ASN) compared to the other subdomains, and runs an entirely different technology stack — Apache/PHP on Linux rather than IIS/ASP.NET on Windows. This was later reinforced by Shodan data, which revealed this host carries the highest concentration of critical vulnerabilities found in the entire assessment, confirming that infrastructure diversity correlated directly with elevated risk.

3. Which service would you investigate first?

Based on the complete evidence set, both primary web services warrant urgent investigation, but the Apache HTTP service on rest.vulnweb.com would now be the top priority, given Shodan's confirmation of 21 associated CVEs for 2026, including four rated Critical (CVSS 9.1–9.8). This supersedes the initial Nmap/Gobuster-based assessment, which had flagged the ASP.NET/IIS service on testaspnet.vulnweb.com as highest priority due to its outdated framework and unencrypted login system — that service remains a close second priority given its live, unencrypted authentication endpoint.

4. Which Gobuster finding was most valuable?

The discovery of `/login.aspx` on `testaspnet.vulnweb.com` was the most valuable finding. It exposes a live, unencrypted authentication endpoint on a host confirmed to run an outdated ASP.NET Framework, meaning submitted credentials travel in plaintext and are vulnerable to interception. Combined with the discovery of `/signup.aspx`, this creates a realistic, exploitable attack path and connects findings across the Nmap, Gobuster, and Shodan phases into a single coherent risk narrative.

5. What does the attack surface look like?

The attack surface consists of six subdomains spanning two distinct, independently managed AWS infrastructure clusters (Linux/Apache in us-east-1, Windows/IIS in us-west-2). Externally, this presents as two web applications with no TLS encryption anywhere: one running a critically vulnerable Apache version with 21 associated CVEs, and another running a legacy ASP.NET application with a live, unencrypted authentication system, user registration, and a likely input-processing endpoint. Legacy artifacts (FrontPage remnants, CGI directories, leftover test files) add minor additional surface but were found to be properly access-restricted. One subdomain (`testphp.vulnweb.com`) was unresponsive, representing a possible unknown/unmonitored gap. Overall, the surface is broad, fragmented across inconsistent infrastructure, and centered on unpatched software rather than a single point of failure.

6. What would your next steps be if given additional time?

- Manual testing of `comments.aspx` for stored XSS given its apparent role in processing user input.
- Attempting authenticated testing against `login.aspx/signup.aspx` to assess session management and password policy strength.
- running Gobuster with a larger wordlist and additional extensions (`.sql`, `.old`, `.zip`) against both hosts for deeper file discovery.
- Retrying enumeration against `rest.vulnweb.com` with tuned rate-limiting to bypass the traffic filtering encountered.
- Manually validating a subset of the CVEs identified via Shodan against the live Apache instance to confirm real exploitability rather than relying solely on version-based inference.
- Investigating the cause of `testphp.vulnweb.com`'s non-responsiveness.